

اليوم 48 - أساسيات الأمان Security Fundamentals

مقدمة عن أمن الشبكات

أمن الشبكات هو موضوع حيوي يتزايد أهميته مع تزايد الاعتماد على الإنترنت والخدمات الرقمية. كل يوم، نسمع عن اختراقات أمنية جديدة تسربت فيها بيانات ملايين المستخدمين، أو هجمات إلكترونية شلت أنظمة شركات كبرى. في هذا الدرس، سنغطي المفاهيم الأساسية لأمن الشبكات التي يحتاجها كل مهندس شبكات، بدءاً من المبادئ الأساسية للأمن (CIA Triad) وصولاً إلى تقنيات المصادقة المركزية (AAA) والبروتوكولات المستخدمة لهذا الغرض. فهم أساسيات الأمان ليس مجرد إضافة لسيرتك الذاتية، بل هو ضرورة ملحة لحماية شبكتك وبيانات مؤسستك.

مبادئ الأمان الأساسية: CIA Triad

CIA Triad هي المبادئ الثلاثة الأساسية التي يقوم عليها أمن المعلومات. الحرف C يرمز إلى Confidentiality (السرية)، وهي ضمان أن المعلومات لا يمكن الوصول إليها إلا من قبل الأشخاص المصرح لهم فقط. يتم تحقيق السرية باستخدام التشفير (Encryption) سواء كان التشفير في أثناء النقل (مثل HTTPS و SSH و VPN) أو التشفير في أثناء التخزين (مثل BitLocker أو تشفير قاعدة البيانات). الحرف I يرمز إلى Integrity (السلامة)، وهي ضمان أن المعلومات لم يتم التلاعب بها أو تغييرها من قبل أشخاص غير مصرح لهم. يتم تحقيق السلامة باستخدام التوقيعات الرقمية (Digital Signatures) ووظائف التجزئة (Hash Functions) مثل SHA-256 و MD5. الحرف A يرمز إلى Availability (التوفر)، وهي ضمان أن المعلومات والخدمات متاحة عند الحاجة إليها. يتم تحقيق التوفر باستخدام التكرار (Redundancy) والتوازن (Load Balancing) وخطط التعافي من الكوارث (Disaster Recovery). هذه المبادئ الثلاثة تشكل الأساس لبناء أي نظام أمني فعال.

أنواع التهديدات الأمنية

هناك عدة أنواع من التهديدات التي يجب أن يكون كل مهندس شبكات على دراية بها. هجمات DoS (Denial of Service) و DDoS (Distributed Denial of Service) تهدف إلى تعطيل الخدمة عن طريق إغراقها بكمية هائلة من حركة المرور، مما يمنع المستخدمين الشرعيين من الوصول إليها. هجمات الاستطلاع (Reconnaissance Attacks) تهدف إلى جمع معلومات عن الشبكة قبل تنفيذ هجوم فعلي، مثل مسح المنافذ (Port Scanning) باستخدام أدوات مثل Nmap. هجمات الوسيط (Man-in-the-Middle Attacks) يقوم فيها المهاجم باعتراض الاتصال بين طرفين والتجسس على البيانات أو التلاعب بها. الهندسة الاجتماعية (Social Engineering) هي هجمات تستهدف البشر بدلاً من التكنولوجيا، مثل التصيد (Phishing) حيث يرسل المهاجم رسائل بريد إلكتروني تبدو وكأنها من مصادر موثوقة لخداع الضحية لإفشاء معلومات حساسة. البرامج الضارة (Malware) تشمل الفيروسات (Viruses)، وأحصنة طروادة (Trojans)، وبرامج الفدية (Ransomware)، وبرامج التجسس (Spyware).

AAA: Authentication, Authorization, Accounting

AAA هو إطار عمل أمني يستخدم للتحكم في الوصول إلى موارد الشبكة. Authentication (المصادقة) هي عملية التحقق من هوية

المستخدم، وتتم عادة عبر اسم مستخدم وكلمة مرور، ويمكن إضافة عوامل إضافية للمصادقة متعددة العوامل (MFA). Authorization). (التفويض) هي تحديد ما يمكن للمستخدم فعله بعد المصادقة، مثل الأوامر التي يمكنه تنفيذها أو الواجهات التي يمكنه الوصول إليها. Accounting (المحاسبة) هي تسجيل جميع الأنشطة التي قام بها المستخدم، مثل وقت الدخول والخروج والأوامر التي نفذها. يوفر AAA إدارة مركزية للمستخدمين وصلاحياتهم بدلاً من إدارة حسابات المستخدمين على كل جهاز على حدة. يتم تطبيق AAA باستخدام خوادم مركزية مثل Cisco ISE أو FreeRADIUS أو Microsoft NPS. لتفعيل AAA على أجهزة سيسكو، نستخدم الأمر `aaa new-model` ثم نحدد طرق المصادقة والتفويض والمحاسبة.

+RADIUS vs TACACS

بروتوكول RADIUS و TACACS+ هما البروتوكولان الرئيسيان المستخدمان للتواصل مع خوادم RADIUS. AAA. يستخدم بروتوكول UDP (المنفذ 1812 للمصادقة و 1813 للمحاسبة). RADIUS يقوم بتشفير كلمة المرور فقط أثناء الإرسال، بينما تبقى بقية الحزمة (مثل اسم المستخدم) غير مشفرة. RADIUS يقوم بدمج المصادقة والتفويض في حزمة واحدة. من ناحية أخرى، TACACS+ (Terminal Access Controller Access-Control System Plus) هو بروتوكول مملوك لشركة سيسكو ويستخدم بروتوكول TCP (المنفذ 49). يقوم TACACS+ بتشفير الحزمة بالكامل (بما في ذلك اسم المستخدم وكلمة المرور وجميع المعلومات)، ويفصل بين المصادقة والتفويض والمحاسبة (ثلاث عمليات منفصلة). لهذه الأسباب، يعتبر TACACS+ أكثر أماناً وتفصيلاً، وهو البروتوكول الموصى به من سيسكو لإدارة أجهزتها. كل بروتوكول له استخداماته: RADIUS شائع في مصادقة مستخدمي الشبكات اللاسلكية و VPN، بينما TACACS+ شائع في إدارة أجهزة الشبكات.

```
! على جهاز سيسكو TACACS+ مع AAA تكوين !
Router(config)# aaa new-model
Router(config)# tacacs server TACACS1
Router(config-server-tacacs)# address ipv4 192.168.100.10
Router(config-server-tacacs)# key StrongTacacsKey123
!
Router(config)# aaa authentication login default group tacacs+ local
Router(config)# aaa authorization exec default group tacacs+ local
Router(config)# aaa accounting exec default start-stop group tacacs+
!
Router(config)# line vty 0 15
Router(config-line)# login authentication default
Router(config-line)# authorization exec default
Router(config-line)# accounting exec default
```

نصيحة مهمة: دائماً أضف الكلمة `local` كمصادقة احتياطية (Fallback) عند تكوين AAA. إذا تعطل خادم TACACS+ أو RADIUS لأي سبب، سيعود الجهاز إلى المصادقة باستخدام قاعدة البيانات المحلية (username secret) مما يضمن عدم فقدان الوصول إلى الجهاز. تذكر أن فقدان الوصول إلى أجهزة الشبكة (Lockout) كارثة إدارية حقيقية.

ممارسات الأمان العامة (Best Practices)

هناك مجموعة من الممارسات الأمنية الأساسية التي يجب تطبيقها في أي شبكة. أولاً، قم بتعطيل الخدمات غير الضرورية (Disable Unused Services) مثل HTTP Server و BOOTP و IP Source Routing و CDP على الواجهات الخارجية. ثانياً، استخدم كلمات مرور قوية (Strong Passwords) بطول لا يقل عن 8-10 أحرف وتحتوي على أحرف كبيرة وصغيرة وأرقام ورموز. ثالثاً، قم بتشفير كلمات المرور المخزنة في ملفات التكوين باستخدام الأمر `service password-encryption` واستخدم كلمة مرور تشفير قوية لـ `Enable Secret` بدلاً من `Enable Password`. رابعاً، قم بتقييد الوصول الإداري للأجهزة باستخدام `Access Control Lists (ACLs)` لتحديد العناوين المسموح لها بالاتصال بـ `SSH` و `SNMP`. خامساً، حافظ على تحديث أنظمة `IOS` بإصداراتها الأمنية الأخيرة (Security Updates). سادساً، قم بعمل نسخ احتياطية منتظمة لتكوينات الأجهزة واحفظها في مكان آمن. سابعاً، طبق مبدأ أقل صلاحية (Least Privilege) حيث تعطي كل مستخدم الحد الأدنى من الصلاحيات اللازمة لأداء مهامه فقط.

```
Router(config)# service password-encryption
Router(config)# enable secret SuperSecureEnablePass
Router(config)# security passwords min-length 10
Router(config)# no ip http server
Router(config)# no ip bootp server
Router(config)# no ip source-route
Router(config)# ip dhcp snooping
```

الأمر show aaa

لتشخيص حالة AAA على جهاز سيسكو، نستخدم الأمر `show aaa` الذي يعرض الحالة العامة لخدمة AAA. الأمر `show aaa servers` يعرض حالة خوادم AAA المتصلة (RADIUS أو TACACS+) بما في ذلك عدد الطلبات المرسلة والردود المستلمة وحالة الخادم. الأمر `show aaa sessions` يعرض جلسات AAA النشطة حالياً. الأمر `show tacacs` يعرض إحصائيات خاصة بخوادم TACACS+. الأمر `show radius statistics` يعرض إحصائيات خاصة بخوادم RADIUS.

```
Router> show aaa servers
Router> show aaa sessions
Router> show tacacs
```

في الختام، أمن الشبكات ليس مجرد مجموعة من الأدوات والتقنيات، بل هو عقلية ومنهجية عمل. فهم أساسيات CIA Triad وأنواع التهديدات و AAA وبروتوكولات المصادقة سيساعدك في بناء شبكات أكثر أماناً ومرونة. تذكر أن الأمان عملية مستمرة وليس منتجاً نهائياً، وأن أهم عنصر في أي نظام أمني هو الوعي والالتزام بالممارسات الجيدة من قبل جميع العاملين في مجال تقنية المعلومات.